

Stronger anonymisation and a more formal DICOM Workbench

Research and implementation roadmap | 5 September 2026

Audience: project owner, student contributors and future reviewers. Scope: local macOS educational classic CT/MR workbench, audited at commit f8d906e before this increment. UK context is primary; US HIPAA is included as a comparison, not an assumption of jurisdiction. No clinical deployment, certification or unconditional anonymity claim is made.

Direct answer

The project should strengthen three separate things: the transformation itself, evidence about the exact exported result, and the process used to decide whether that result can be shared. More tag deletion alone is insufficient. Prioritise permanent manual pixel redaction, independent post-write assertions and honest assessment states; next repair the supported DICOM object definitions and establish an external-validator baseline. Add evaluated local OCR assistance later. Treat full-volume defacing and institutional deployment as separate projects.

This inventory contains **96 distinct improvement actions** across 12 areas. It is exhaustive for the identified threat families and present scope, not a proof that no future attack or vendor-specific case exists. P0 means the immediate safety/evidence foundation; P1 means the next engineering milestone; P2 means a larger scoped extension. Most actions remain planned. The implementation section identifies exactly what was started and completed in this increment.

What the audit found

The existing application deliberately retains a narrow numeric allowlist, blanks identity fields, generates replacement identifiers, drops all sequences/private/unknown fields and rebuilds file metadata/preamble. It accepts only one uncompressed classic CT/MR monochrome frame with 16 allocated/stored bits. These are useful constraints, but its previous export checks mainly proved that the file reopened and pixel bytes stayed unchanged.

A concrete interoperability defect remains: the policy removes MR ScanningSequence and SequenceVariant, although these are Type 1 attributes, as well as Type 2 ScanOptions and MRAcquisitionType. A file can display while failing its information-object requirements. Fix this with validated coded source values and complete conditional-module tests, not by inventing scan facts. [DICOM MR requirements](#)

DICOM confidentiality-profile conformance requires appropriate protection and retention at every relevant nesting level and preservation of object integrity. Pixel cleaning and recognisable-feature cleaning add different obligations. A rectangular mask in the viewer does not clean stored pixels. [DICOM profiles](#), [Clean Pixel Data](#)

The project therefore must continue to say that it implements a custom subset. Neither a successful parser reopen nor an independent validator is official certification or proof of anonymity. [Validator limitations](#)

Evidence that changes the priorities

ICO distinguishes pseudonymisation from anonymisation; separately held linking information and the recipient's ability to identify someone matter. Its current guidance is under review following the Data (Use and Access) Act, so a static UK-compliance label would be inappropriate. HHS describes Safe Harbor and Expert Determination as distinct routes with additional conditions; a DICOM tag scrubber or a user checkbox does not establish either. [ICO pseudonymisation](#), [HHS guidance](#)

OCR is useful assistance, but published results include misses and institution-specific validation assumptions. Defacing research also reports residual recognition and measurement changes. These support versioned evaluation, human review and utility testing, rather than a universal automatic-clean verdict. Study results are not Mac performance estimates or universal error rates. [Burned-in text study](#), [Neuroimaging study](#), [ADNI4 validation workflow](#)

Formal engineering should draw on the final NIST SSDF v1.1; v1.2 remains an initial public draft in the material retrieved. Repeatable fixtures are useful but do not prove reproducible software builds. Build provenance needs verification, and it cannot prove privacy effectiveness. [NIST final](#), [NIST draft](#), [Reproducible Builds definition](#), [SLSA verification](#)

Stack decisions

Keep Python/pydicom for the small local transformation service and the existing browser Canvas for this increment. Add pure-Python replacement and verifier modules; no cloud service, AI model or native codec is needed for bounded 16-bit rectangular erasure. Keep the UI and CLI on the same core transformation path.

For the next validation milestone, evaluate a pinned dicom3tools dciodvfy build and the Python dicom-validator with an explicit DICOM edition. The latter shares pydicom parsing and is not a fully independent parser. No validator installation or pass is claimed in this increment. [dciodvfy](#), [dicom-validator](#)

Do not add Cornerstone3D merely to strengthen anonymisation: it can help future stack navigation and richer rendering, but it is not a privacy engine. Do not use an LLM as an authoritative PHI-removal judge. Compare local OCR candidates on measured misses, coverage and Mac resource use before choosing one. Treat vendor-specific private retention and date retention as utility tradeoffs rather than default privacy improvements.

Purpose, claims and risk ownership

Evidence context: [DICOM confidentiality profiles](#), [ICO pseudonymisation](#), [ICO effective anonymisation](#), [ICO governance](#), [HHS de-identification guidance](#). The actions below are project-specific engineering proposals.

A001 [P0] Separate five claims. Distinguish metadata processing, selected-region erasure, human inspection, technical verification and disclosure-risk assessment in UI and reports.

A002 [P0] Define intended use. Write a synthetic/public teaching-only use statement and separate any future institutional deployment requirements.

A003 [P0] Publish the input envelope. List accepted SOP classes, transfer syntaxes, dimensions, sample depths and rejected features; test every boundary.

A004 [P0] Create a threat model. Map metadata, pixels, recognisable anatomy, file containers, local access and linked external data to mitigations and residual risks.

A005 [P0] Create a risk register. Assign an owner, severity, evidence, residual risk and review date to each privacy failure mode.

A006 [P1] Define a release model. Distinguish public internet publication from controlled research access; review risk for the intended recipients.

A007 [P1] Set honest acceptance gates. Define what blocks export, release and new-format support; never convert a software test pass into a clinical approval.

A008 [P1] Record external assurance needs. Specify independent imaging/privacy review before institutional real-data use, without pretending the prototype has obtained it.

Metadata policy strength

Evidence context: [DICOM confidentiality profiles](#), [DICOM Basic Profile](#), [DICOM descriptor cleaning](#), [DICOM safe private retention](#), [DICOM MR module requirements](#). The actions below are project-specific engineering proposals.

A009 [P0] Version the policy contract. Give retained, emptied, replaced and rejected fields an immutable policy identifier, rationale and regression references.

A010 [P0] Assert the saved metadata. Reopen the output and check permitted fields, empty placeholders, replaced source UIDs and clean file metadata; inject violations to prove rejection.

A011 [P0] Check retained value representations. Reject a numeric imaging tag encoded with text or another unexpected VR, even if its value parses as a number.

A012 [P1] Validate multiplicity and ranges. Test VM, finite values, dimensional constraints and plausible bounds; do not treat arbitrary numeric strings as automatically harmless.

A013 [P1] Implement conditional profile actions. Model D/Z/X/K/C/U and IOD-dependent variants per supported object; do not merely extend a deletion list.

A014 [P1] Preserve required coded acquisition facts. Repair missing MR required fields with validated source values, never invented acquisition facts; reject unknown cases.

A015 [P1] Handle sequences deliberately. Recursively clean required sequences and their references; keep dropping unsupported trees until safe semantics and validity are demonstrated.

A016 [P1] Keep private retention evidence-based. Default to deletion; require vendor/version-specific proof, private creator handling and sentinel tests before any retention exception.

Hidden metadata and alternate containers

Evidence context: [DICOM confidentiality profiles](#), [DICOM graphics cleaning](#), [DICOM structured-content cleaning](#), [DICOM descriptor cleaning](#). The actions below are project-specific engineering proposals.

A017 [P0] Test nested identifier traps. Plant names in multiple sequence depths and verify output DICOM, reports and errors do not contain them.

A018 [P0] Test header and preamble traps. Plant identifiers in file metadata, implementation text and the preamble; confirm reconstruction removes them.

A019 [P1] Remove historical originals. Explicitly exercise Original Attributes, modified-attribute histories, signatures and encrypted originals; never carry recovery copies into public exports.

A020 [P1] Cover icons and thumbnails. Reject or clean embedded icons and alternate image representations that might still contain the original text.

- A021 [P1] Cover non-pixel graphics.** Test overlays, presentation states, shutters, curves and annotations as separate data paths; visual concealment is insufficient.
- A022 [P1] Cover directories and sidecars.** When adding folders, rebuild or exclude DICOMDIR, JSON, XML, filenames and archive paths using output-only information.
- A023 [P2] Treat structured reports separately.** Keep SR, PDF, encapsulated documents, waveforms and specimen content unsupported until dedicated policies exist.
- A024 [P1] Review unknown and retired tags.** Fail closed or drop according to an explicit policy; add regression cases for new dictionaries and unknown standard attributes.

Permanent pixel redaction

Evidence context: [DICOM Clean Pixel Data](#), [DICOM recognisable visual features](#), [DICOM graphics cleaning](#). The actions below are project-specific engineering proposals.

- A025 [P0] Erase stored samples.** Replace chosen image samples in the actual exported PixelData with a constant independent of their original values.
- A026 [P0] Validate source-coordinate rectangles.** Require bounded integer x/y/width/height, a finite rectangle count and explicit half-open coordinate semantics.
- A027 [P0] Handle display interpretation.** Test signed/unsigned pixels, MONOCHROME1/2 and positive/negative rescale when selecting a dark stored replacement.
- A028 [P0] Verify every selected sample.** Use a separate decoded-value inspection after saving, rather than trusting the writer or a screenshot.
- A029 [P0] Verify every unselected sample.** Reject output if any outside-mask pixel changes; test corners, overlaps, single pixels and full-image masks.
- A030 [P0] Make pending selections obvious.** Outline pending regions, block downloads until applied or discarded, and preview the resulting saved pixels after apply.
- A031 [P0] Bind edits to an image revision.** Reject stale jobs; new input, errors, expiry or edits invalidate acknowledgement and old download URLs.
- A032 [P1] Support intentional flagged-image review.** Design a separate quarantined review workflow for BurnedInAnnotation=YES; retain current rejection until unreviewed exports cannot escape.

Human review and student experience

Evidence context: [DICOM Clean Pixel Data](#), [ICO effective anonymisation](#), [ICO governance](#). The actions below are project-specific engineering proposals.

- A033 [P0] Provide a fake-text challenge.** Generate deterministic original glyphs and fake identifiers at known coordinates, with no real patient information.
- A034 [P0] Offer pointer and numeric selection.** Support drag selection and keyboard-accessible coordinates mapped to source pixels at every viewport size.
- A035 [P0] Explain permanence.** State that apply creates altered image data and that reimport is needed to start over; distinguish discard-selection from undoing a saved edit.
- A036 [P0] Report remaining uncertainty.** After an edit, say selected regions only; keep recognisable anatomy and unselected image content explicitly unassessed.

- A037 [P1] Review the exact export.** Tie review state and a digest to the current output bytes and make any later transformation invalidate it.
- A038 [P1] Add a structured review checklist.** Check corners, interior annotations, multiple windows, graphics and anatomy; record completion without copying observed identifiers.
- A039 [P1] Expose region history safely.** List coordinates and removal operations for review while omitting source filenames, original text, thumbnails and mappings.
- A040 [P1] Validate accessibility in depth.** Exercise screen readers, Safari, keyboard order, focus restoration, touch drag cancellation, zoom and contrast for privacy-critical controls.

Local OCR assistance and evaluation

Evidence context: [DICOM Clean Pixel Data](#), [DICOM metadata and burned-in text study](#). The actions below are project-specific engineering proposals.

- A041 [P1] Benchmark candidate local detectors.** Compare a simple CPU OCR engine with a local text detector on the same labelled corpus; record Mac hardware and runtime.
- A042 [P1] Separate detection from interpretation.** Treat all text locations as candidates; names-only recognition can miss dates, record numbers, URLs and barcodes.
- A043 [P1] Pin model provenance.** Record model version, weights digest, training/evaluation provenance, licence and supported languages.
- A044 [P1] Keep inference offline.** Install models explicitly; block runtime network and test failure when a model is missing instead of downloading silently.
- A045 [P1] Test difficult text systematically.** Include tiny, rotated, low-contrast, inverted, interior and multilingual examples across relevant display windows.
- A046 [P1] Measure misses directly.** Report identifier-level and image-level false negatives with denominators; do not substitute overall accuracy for privacy recall.
- A047 [P1] Reserve an independent test set.** Separate threshold tuning from validation, stratify modalities/vendors and record known failures without overgeneralising.
- A048 [P1] Require correction and fail states.** Make suggestions editable; timeout, detector error and no detections stay unresolved rather than becoming a clean-image verdict.

Recognisable anatomy and residual linkage

Evidence context: [DICOM recognisable visual features](#), [DICOM UID retention](#), [Changing the face of neuroimaging research](#), [ADNI4 face de-identification validation](#). The actions below are project-specific engineering proposals.

- A049 [P2] Require complete volume support.** Do not advertise defacing on one slice; validate geometry, ordering and reconstruction of a supported head/neck volume first.
- A050 [P2] Choose defacing by acquisition type.** Evaluate supported CT/MR sequences and unsupported edge cases rather than applying one algorithm universally.
- A051 [P2] Review every processed volume.** Inspect facial removal and preservation of required brain/anatomical regions before a research release.

- A052 [P2] Measure scientific utility loss.** Compare downstream measurements before and after defacing against predefined tolerances and record failures.
- A053 [P2] Evaluate realistic residual recognition.** Assess reconstruction and matching attacks on authorised test materials; do not claim zero recognition from older published rates.
- A054 [P2] Cover other identifying visual features.** Assess tattoos, implants, distinctive pathology, dental structure and localisers where relevant to the intended release.
- A055 [P1] Document unchanged-pixel linkage.** Explain that a recipient with an original image may match unchanged areas despite new UIDs or erased text.
- A056 [P2] Prefer access restriction when needed.** For high-utility images that cannot be adequately cleaned, use controlled access or exclude them rather than promising anonymity.

Related files, dates and demographic utility

Evidence context: [DICOM confidentiality profiles](#), [DICOM temporal retention options](#), [DICOM patient-characteristic retention](#), [DICOM UID retention](#), [DICOM safe private retention](#). The actions below are project-specific engineering proposals.

- A057 [P1] Map related identifiers consistently.** Use fresh project-scoped replacements across studies, series, instances and frame-of-reference links; avoid global deterministic patient hashes.
- A058 [P1] Validate the reference graph.** Reject dangling references, duplicate instance IDs and inconsistent entity-level metadata before a batch export.
- A059 [P1] Keep keys separate if mappings exist.** Store optional linkage maps outside public exports with explicit access, retention and destruction rules.
- A060 [P2] Design date shifting as an option.** Keep public-teaching retention conservative; only add date modification for a documented longitudinal research need.
- A061 [P2] Test temporal relationships.** Cover intervals, fractional times, midnight, time zones, leap days and incomplete dates with consistent transformations.
- A062 [P2] Assess demographic combinations.** Minimise age, sex, location and rare characteristics together; retaining one field can change linkage risk when combined with others.
- A063 [P2] Constrain site and device retention.** Enable institution, device or private acquisition fields only under a documented purpose and risk assessment.
- A064 [P1] Keep production IDs fresh.** Compare semantic test outputs separately from random identifiers; do not weaken unlinkability just to make whole DICOM bytes deterministic.

Format expansion and parser resilience

Evidence context: [DICOM confidentiality profiles](#), [DICOM MR module requirements](#), [dciodvfy and dcentvfy](#), [dicom-validator](#). The actions below are project-specific engineering proposals.

- A065 [P1] Baseline an independent IOD validator.** Run a pinned external validator on synthetic CT/MR outputs, sanitise findings, and document every unresolved failure.
- A066 [P1] Distinguish parser from IOD checks.** Use a different parser/tool for cross-checks where practical; pydicom-based validation alone shares parser failure modes.

A067 [P1] Repair the supported IODs first. Close required/conditional attribute gaps before announcing a formal DICOM profile or expanding supported formats.

A068 [P2] Add 12-bit support deliberately. Test BitsStored, HighBit, signed extension and unused-bit handling; prevent embedded information surviving in ignored bits.

A069 [P2] Add compressed input with limits. Pin codecs, enforce decoded-size limits, normalise output encoding and verify redaction after decompression/re-encoding.

A070 [P2] Inspect every frame. Gate multiframe support on frame-by-frame cleaning, functional-group handling, timing and per-frame review coverage.

A071 [P1] Bound parser resources. Test malicious lengths, sequence depth, huge item counts, slow input and memory/CPU budgets before accepting more complex files.

A072 [P1] Reject unsupported presentation semantics. Keep LUT, padding, palette, photometric and orientation cases rejected until rendering and exported meaning are tested.

Independent testing and evidence

Evidence context: [dciodvfy](#) and [dcenvfy](#), [dicom-validator](#), [NIST Secure Software Development Framework](#), [Reproducible Builds definition](#). The actions below are project-specific engineering proposals.

A073 [P0] Use property-based acceptance tests. Compare the exact exported samples to an independently built mask and assert the intended invariants across representations.

A074 [P0] Prove the verifier can fail. Inject unredacted selected pixels, outside-mask changes, retained identifiers, original UIDs and forbidden fields.

A075 [P0] Keep privacy-safe golden fixtures. Version synthetic trap cases and public sample provenance; never add confidential scans to test history.

A076 [P1] Add generated hostile cases. Use bounded fuzzing and property tests for malformed encodings, duplicates, nesting, invalid VR/VM and arithmetic edges.

A077 [P1] Automate full browser workflows. Cover selections, acknowledgement, stale results, downloads, errors, expiry, accessibility and the displayed/exported pixel relationship.

A078 [P1] Publish an evidence manifest. Record source revision, policy, toolchain, fixture digests, commands, outcomes and coverage limitations for each release.

A079 [P1] Separate kinds of reproducibility. Distinguish deterministic fixtures, semantic output repeatability and byte-identical software builds; test each claimed property.

A080 [P1] Create a regression review process. Keep every discovered leak as a synthetic regression case and require a review of related failure paths before closing it.

Application security and data lifecycle

Evidence context: [ICO pseudonymisation](#), [ICO governance](#), [NIST Secure Software Development Framework](#). The actions below are project-specific engineering proposals.

A081 [P0] Preserve loopback isolation. Keep same-origin Host/Origin checks, per-launch tokens, no-store headers and explicit local assets across new endpoints.

A082 [P0] Fail closed on failed edits. Do not offer an old file after invalid selections, interrupted processing or verification failures; bound edit payload size.

A083 [P1] Avoid sensitive audit content. Test that errors, logs, reports, URLs and filenames omit raw identifiers, OCR text, source hashes and secret tokens.

A084 [P1] Test expiry and memory lifecycle. Clear current references at timeout/new input; document that Python/browser memory disposal is not secure erasure.

A085 [P1] Constrain dependencies and network. Keep third-party scripts out of the viewer, scan dependencies and prevent external calls during all processing paths.

A086 [P1] Harden temporary and export files. Use exclusive output creation, safe names, restricted temporary locations and cleanup tests; treat downloaded files as user-managed copies.

A087 [P1] Document local attacker limits. Cover malicious browser extensions, other local processes and shared-computer use in the threat model without pretending loopback is full isolation.

A088 [P2] Reassess before server deployment. Require authentication, authorisation, TLS, tenancy isolation, monitoring and secure storage design before any hosted real-data service.

Project formality and release discipline

Evidence context: [ICO governance](#), [HHS de-identification guidance](#), [NIST Secure Software Development Framework](#), [NIST SSDF revision status](#), [Reproducible Builds definition](#), [SLSA artifact verification](#). The actions below are project-specific engineering proposals.

A089 [P0] Create a traceable requirements table. Link each privacy requirement to code, tests, evidence and remaining limitations; keep implemented and planned work distinct.

A090 [P0] Publish agent-ready work packages. Give each task scope, dependencies, prohibited shortcuts, acceptance tests and a handoff format; build small reviewable changes.

A091 [P1] Maintain changelog and version rules. Version application, report schema, metadata policy and pixel policy independently when their contracts change.

A092 [P1] Harden CI and review. Pin workflow actions, use least privilege, test clean checkouts on Mac ARM/Intel and Linux, and require privacy-critical review.

A093 [P1] Document component provenance. Generate an SBOM/licence inventory and scan pinned dependencies; preserve model and dataset notices separately from code licensing.

A094 [P1] Verify release origin. Publish checksums and build provenance, then document verification against the expected source, builder and parameters.

A095 [P1] Plan maintenance and incidents. Define supported versions, confidential reporting, triage, withdrawal/rollback and reevaluation triggers for new standards or attacks.

A096 [P2] Seek external review before claims. Arrange imaging-domain and privacy assessment for the intended use; no badges, attestations or validators are substitutes for that review.

First implementation: delivered scope

This increment adds a constant-value stored-pixel rectangle operation, independently indexed decoded-pixel verification, post-write custom metadata assertions, retained numeric VR checks, and a deterministic fake-text exercise. The interface supports drawing and numeric coordinates. Pending selections suspend downloads. Applying an edit creates a new result, invalidates the old URL and requires fresh acknowledgement. Reports identify the exact output by SHA-256 and distinguish selected-region verification from complete anonymity. The CLI accepts a JSON region file.

The first implementation intentionally supports one applied selection set per loaded image, up to 32 rectangles. Reimport to edit again. The source file remains unchanged. Inputs declaring BurnedInAnnotation=YES or RecognizableVisualFeatures=YES still fail the existing input gate; this increment does not quietly bypass it. The synthetic exercise omits the annotation declaration and contains only deliberately fake text. Missing/NO declarations never establish clean pixels.

No automatic OCR, volume defacing, full PS3.15 profile, full IOD validation or clinical approval is implemented. The existing MR required-field gap remains a priority for the next milestone. The metadata verifier shares the declared allowlist and pydicom parser, so it is an additional assertion layer rather than external certification. Redaction tests use an independent NumPy mask to check the write results; injected corruption exercises the verifier's failure paths.

Execution order and agent prompts

Use the work packages in docs/prompts. Start with output contracts and redaction (implemented here), then follow with IOD/profile correctness and automated browser evidence. OCR requires a separate evaluation corpus before detector integration. Batch/date work depends on reference-graph validation; defacing depends on full-volume support. Release engineering can proceed alongside feature work once its exact artifacts and claims are defined.

Every prompt requires a concrete testable result, explicit non-goals, privacy-preserving evidence and a truthful handoff. A prompt is not evidence that its feature exists. No future roadmap item should be marked complete until its acceptance criteria pass.

Research coverage and limitations

Discovery covered DICOM profiles and options, current code, output validity, independent validators, UK/US privacy framing, OCR, facial de-identification and secure/reproducible release practices. Two bounded research lanes reviewed standards and assurance. Follow-up checked consequential profile, MR-module, regulator and NIST-version claims against primary material visible to the coordinator.

The coordinator's direct PMC reads encountered a browser challenge for two studies; the research agent retrieved the study material. Study conclusions are therefore reported qualitatively, with explicit generalisation limits, and no unsupported numerical risk or performance estimate is used. Tool installation compatibility, new OCR model licensing and real institutional privacy risk were not assessed. Those are named work items rather than assumed facts.

Research stopped after all material threat families had primary evidence or an explicit limitation and further broad searches were unlikely to change the first build order. This is a dated engineering assessment; new standards, datasets, dependency changes and attack methods require reevaluation.

Source register

All sources were accessed on 5 September 2026. DICOM URLs are live current-edition links; the retrieved edition was 2026c. Retain the edition in future validation evidence rather than silently following latest.

[DICOM confidentiality profiles](#). DICOM Standards Committee; 2026c.

[DICOM Basic Profile](#). DICOM Standards Committee; 2026c.

[DICOM Clean Pixel Data](#). DICOM Standards Committee; 2026c.

[DICOM recognisable visual features](#). DICOM Standards Committee; 2026c.

[DICOM graphics cleaning](#). DICOM Standards Committee; 2026c.

[DICOM structured-content cleaning](#). DICOM Standards Committee; 2026c.

[DICOM descriptor cleaning](#). DICOM Standards Committee; 2026c.

[DICOM temporal retention options](#). DICOM Standards Committee; 2026c.

[DICOM patient-characteristic retention](#). DICOM Standards Committee; 2026c.

[DICOM UID retention](#). DICOM Standards Committee; 2026c.

[DICOM safe private retention](#). DICOM Standards Committee; 2026c.

[DICOM MR module requirements](#). DICOM Standards Committee; 2026c.

[dciodvfy and dcentvfy](#). David A. Clunie; 31 August 2021 documentation.

[dicom-validator](#). pydicom maintainers; living repository, accessed 5 September 2026.

[ICO pseudonymisation](#). Information Commissioner's Office; guidance under review, accessed 5 September 2026.

[ICO effective anonymisation](#). Information Commissioner's Office; living guidance, accessed 5 September 2026.

[ICO governance](#). Information Commissioner's Office; living guidance, accessed 5 September 2026.

[HHS de-identification guidance](#). US Department of Health and Human Services; reviewed 3 February 2025.

[DICOM metadata and burned-in text study](#). Macdonald et al.; 2024.

[Changing the face of neuroimaging research](#). Schwarz et al.; 2021.

[ADNI4 face de-identification validation](#). Schwarz et al.; 2024.

[NIST Secure Software Development Framework](#). Souppaya, Scarfone and Dodson / NIST; v1.1 final, February 2022.

[NIST SSDF revision status](#). NIST; v1.2 initial public draft, 17 December 2025.

[Reproducible Builds definition](#). Reproducible Builds project; living definition.

[SLSA artifact verification](#). SLSA project; v1.2.